

Grok Bot 0.18 Study — Learnings for OIKONOMOS

Study: Grok Bot 0.18 (reconstructed) — learnings for OIKONOMOS

Source: `C:\CLAUDECODE_TOOLSETS\oikonomos-gbot-study\grok-bot-0.18-reconstructed-main` (studied 2026-08-26, three parallel deep reads: host runtime/coordinator, router/exec daemons, tests/provenance/security).

Vocabulary map (theirs → ours): **host** = control-plane daemon; **local-exec** = user's machine (dangerous surface); **Auto-review** = policy engine + approval broker; **plugin/connector** = MCP server bundle; **coordinator inference-router** = AgentProvider layer.

Grok Bot is the closest existing artifact to what OIKONOMOS is building — a desktop control plane brokering agent tool calls across Cursor/Claude Code/Codex/OpenRouter with per-action human approval. Its approvals/permission machinery is production-grade; its CI/liveness discipline is weak (the inverse of our gap profile). Below: what to adopt, what to avoid, and how each maps to our non-negotiables.

Tier 1 — adopt directly (maps to non-negotiables)

1. Approval = nonce + generation + epoch triple (NN #8)

Their approval record carries `id` (crypto-random nonce), `hostGeneration` (uuid minted at process start → **restart invalidates all approvals**), `userMessageEpoch` (bumped on every new user message → **a redirect invalidates outstanding approvals**), per-agent `directionEpoch` (per-turn), `toolCallId` scope, TTL. Resolution checks all of them or returns undefined. → OIKONOMOS `approvals` row gains `control_plane_generation`, `user_message_epoch`, `direction_epoch`, `tool_call_id`, `outlives_scope` alongside the nonce. Redemption stays one atomic `UPDATE ... WHERE id=$1 AND status='pending' AND generation=$2 AND epoch=$3 AND expires_at>now() RETURNING *`. TASK-064's invalidation primitive is the right base; extend it with generation+epoch binding. Files: `source/host/runner/sand-auto-review.ts:150`, `source/host/extensions/local-tool-permission/local-tool-permission-controller.ts`.

2. Undescribable ⇒ denied (NN #3, fail closed)

Every wire action is mapped to a human-readable `{action, target}` by a **whitelist** describer; unknown message kinds return `undefined`, and `undefined` ⇒ refused: *"if we cannot render it to a human, we cannot ask about it, therefore we do not run it."* Target >10,000 chars ⇒ refused (can't be shown). → Every connector manifest tool entry must carry a required human-description renderer; broker refuses any tool call it cannot render into an approval card. Files: `source/shared/local-tool-permission-machinery.ts:66-81`.

3. Independent re-verification at the executing process (NN #1 defence-in-depth)

The exec daemon does not trust the caller: it **re-reads the persisted approval store from disk on every request** and **re-derives the action description from the raw payload** — a compromised broker cannot mint an approval for "read file" and send a shell command under it. Approvals file minus retirements (tombstone) file = live grants. → Broker records the approval; the tool-runner independently re-fetches it from Postgres and re-derives `(tool, canonical_args_digest)` before executing. Never accept a caller-supplied "this was approved as X". Revocation = tombstone, not grant-file rewrite. Files: `source/host/local-exec/local-exec-daemon.ts:59`, `local-tool-approvals.ts`.

4. Fail-closed at construction time, not call time (NN #1/#3, ADR-005 liveness)

Their RPC edge throws at startup if any method in the contract table lacks a handler or names an undeclared trust policy — "we forgot to gate the new tool" becomes a boot crash, not a silent hole. Same idea in `assertProductionLocalExecRuntime` (all bindings mandatory, typed error lists what's missing) and the 35-slot extension registry (missing slot ⇒ throw). → PreToolUse broker: a registry mapping every tool name to `{policy, run}`; constructor throws `PolicyMissingError` on any unmapped tool. This is also a natural liveness assertion — the test constructs the broker with an unmapped tool and asserts it throws. Files: `source/electron-main/generated/main-rpc.ts:66`, `source/local-exec-daemon/production-executor.ts:82-181`, `source/host/extensions/registry.ts`.

5. Model-directed refusal messages (novel — a product surface)

Twelve distinct denial texts written *to the model*: what happened, do-not-retry, what to do instead ("say so in chat and use your own computer in the meantime"). Denials **stick** per direction-epoch (refusal memory, sha256(target)-keyed, 512/agent with fail-closed saturation); a retrying agent gets the abandoned message, a new user instruction re-opens the question; flipping to "always" is **not retroactive**. → Our `PolicyDecision.deny` should carry `{code, humanReason, modelGuidance}` and the broker should keep per-turn refusal memory so agents don't burn budget retrying. Files: `local-tool-permission-controller.ts`, `local-tool-permission-machinery.ts:5-14`.

6. Enforce-time re-check of enumeration-time filters (NN #1; feeds TASK-054)

MCP tool disablement is applied at **enumeration** (filter tools list) *and again at invocation* (`executeTool` re-checks the disabled map before dispatch). Assume the model holds a stale tool list. → TASK-054's `allowedTools` derivation must be paired with a call-time re-check against the manifest map inside the broker, not only a mount-time filter. Files: `source/shared/node/mcp/mcp-manager.ts` (`filterDisabledTools` + `executeTool`).

7. Bidirectional inventory closure + canonical digest done right (NN: shared digest impl)

Their packaging verifier requires declared set == packaged set **in both directions** (no missing files, no undeclared/injected files). But their `sha256` helper is re-declared in ~12 files with divergent contracts, and canonicalization relies on implicit sort order — exactly the disease our "one canonical JSON + digest impl in `packages/shared`" rule prevents. Add the liveness test they lack: `digest({a:1,b:2}) === digest({b:2,a:1})` plus a hard-coded fixture hash. Files: `scripts/verify.mjs:175-189`, `scripts/lib/clean-build.mjs:164-191`.

8. Real liveness assertion shapes (ADR-005)

Genuine examples to copy: capability probe on the artifact before launch (scan the packaged binary for the isolation flag's bytes, refuse if absent); denylist-absence recorded as evidence in the run report; **negative-log tripwires** (test fails if the app ever logs a "fallback" line); corpus-size floor (≥ 1000 evidence markers or throw) — a threshold that fails when a control goes inert. → For the broker: assert the PreToolUse hook fired $\geq N$ times per session / audit log grew — the inert-broker failure mode is exactly this. Files: `scripts/native-e2e-check.mjs`, `scripts/verify.mjs:53-54`.

Tier 2 — adopt as designs for upcoming packages

- **Extension kernel** (`source/internal/host-extensions.ts`, 133 dep-free lines): `{id, dependencies, start}` declarations, deterministic topo sort, dependency-scoped injection (an extension physically can't reach an undeclared peer), reverse-order teardown on start failure, cycle errors rendering the path. The right composition skeleton for policy/broker/audit/connectors — but keep typed APIs, not their `Record<string, any>` + `optionalMethod` erosion.
- **Closed error registry with payload allowlist** (`source/shared/errors/registry.ts`): ~340 codes `{code, domain, retryable, summary, payload[]}`; unregistered error → generic code, payload dropped; registered → only declared fields, strings only if `/^[0-9A-Za-z._|-]{1,64}$/`. Solves audit PII leakage (NN #4), metric cardinality, and scattered retryability in one structure.
- **Tool decorators as the enforcement seam** (`source/host/runner/tools/turn-toolset.ts`): plain `{name, execute}` wrapped by `withLocalToolScope` (scope in `AsyncContext`, not args — nested calls inherit it; `finally { completeScope }` retires the approval unconditionally), `withToolTimeout`, `withRecordedToolCallNames` (missing `toolCallId` ⇒ throw; identity is mandatory). Harness-factory middleware chain.
- **Admin ceiling as a rank clamp**: `resolveChoice(choice, ceiling) = rank[choice] <= rank[ceiling] ? choice : ceiling` — org policy can only tighten; four lines; our "no bypass" primitive (`source/shared/local-tool-permission.ts`).
- **Closed method tables** + `Object.hasOwn` for every RPC surface: deny-by-default, prototype-safe, diffable-in-review data.
- **Nonce ledger with input-digest binding** (`prompt-acceptance-ledger.ts`): same nonce + different content ⇒ hard error; replay of a rejection replays the rejection; tri-state lookup `found | not-found | unknown-durability` (never treat "can't tell" as "not seen"). Postgres: unique `(account_slot, client_nonce)` + stored `input_digest` + status enum.
- **Stale-while-revalidate MCP discovery keyed by server-set** (`source/shared/node/mcp/tools-discovery.ts`): sorted-join cache key, requested vs resolved key (race-safe), `getToolsForTurnStart()` never blocks a turn, partial-failure policy per plane. Direct input to TASK-054's live enumeration.
- **Ephemeral loopback MCP bridge** (`source/node-agent-coordinator/routed-mcp-bridge.ts`, ~88 lines): `127.0.0.1:0`, `randomUUID()` capability path, 1 MiB body cap, torn down per turn — the mount point for handing our connector set to CLI harnesses (Codex CLI, Grok Build), and a natural broker interception point for every `tools/call`.

- **Harness-factory settings for Claude Agent SDK** (`provider-session.ts:203`): `tools: []` + only `mcp__<ns>__*` wildcards, `strictMcpConfig: true` (user's own `.mcp.json` can't leak in), `persistSession: false`, `permissionMode: "default"`, bounded `maxTurns`. Note: Claude Code path does not stream (one `text-delta` at the end).
- **Deferred-bundle provider normalization**: every adapter returns `{fullStream, response, usage, extendedUsage, providerMetadata, invocationId}` via `Promise.withResolvers()`, rejecting **all** deferreds on error so no consumer hangs; provider-namespaced metadata (`{anthropic:{totalCostUsd}}`) instead of a forced union. Add a `budget` field — that's where per-routine budget enforcement hooks in. Grok Bot has **no budgets/tiers at all**; we're building what it lacks.
- **Pure-function model selection** (`cursor-session.ts:26`): precedence ladder (role → explicit → env → stored → default) as a pure function of one explicit inputs record. Shape for our Tier-0 router: `resolveRoutine({routineKind, budgetRemaining, override, default})`.
- **Named injectable scheduling policies** (`source/internal/scheduling.ts`): Deadline/Retry/Polling/IdleWatchdog/Expiry/Debounce, Clock-parameterised, constructor-validated, all `.unref()`, all named so `DeadlineExceededError` says which deadline. Replace bare `setTimeout`.
- **Secrets never enter the transcript** (`sand-secret-request.ts`): model requests a *labelled* secret; value flows host→destination; model gets only an acknowledgement string (NN #4). Plus credential-file hygiene: reject symlinks and `(mode & 0o077) !== 0`.
- **Anchor-based patching / atomic file ops**: replace-exactly-once (missing OR ambiguous anchor ⇒ refuse), idempotence short-circuit, output-digest verification; temp+rename `0o600` writes; rename-to-quarantine compare-and-delete; snapshot-act-verify with rollback around any mutating step.
- **Structured blocker lists over booleans**: controls emit `blockers: string[]` with namespaced reasons; verdict = empty list; `not-evaluated` is a distinct state **never treated as pass**.
- **Approval-aware health**: `busyOnlyAwaitingApproval` — don't advance the busy clock while everything is blocked on a human; enables safe drain/upgrade without cancelling human-blocked work.
- **Audit dual-sink** (`action-audit-service.ts`): append-only local JSONL always; backend forwarding filtered + batched + persisted outbox (capped, oldest-dropped) + Retry-After-aware backoff; exhaustive-over-union line formatter so a new action kind is a compile error.

Anti-patterns — do not copy

1. **MockPermissionsService in the production executor graph** — allow-everything permissions and `insecure_none` sandbox policy composed into the real daemon; all enforcement lives one layer up. Single-layer defence is exactly what NN #1 forbids. Keep both layers real.
2. **isReadOnly() regex** guessing tool destructiveness from name/description to drive permission-relevant MCP hints. Manifests must declare `readOnly/destructive` per tool; manifest wins.
3. **~80 source-text regex assertions as the main CI test** (`publication-packaging.test.mjs`): passes on dead code, fails on refactors. Use grep-tests only for provenance/negative controls (`doesNotMatch /ANTHROPIC_API_KEY/` is good); never as substitute for executing the control.

- 4. **Best controls not run by CI:** their verify/audit/e2e scripts are macOS/bootstrap-gated and CI substitutes greps. No CI bypass-grep, no CODEOWNERS. Our NN #2 CI grep + protected-path adversarial review are precisely what this otherwise-rigorous repo lacks — keep them non-negotiable.
- 5. **Live credentials bind-mounted into the sandbox** (`~/.codex`, `~/.claude` read-only into the Docker box, with unrestricted egress). Broker short-lived scoped tokens over a loopback channel instead.
- 6. **Docker sandbox is containment, not isolation:** no `--cap-drop`, no `--user` (root in-container), no network restriction, default `"local"` auth token with non-constant-time compare. Their loopback-only port binds, readonly mounts, content-addressed runtime with byte verification, and ownership-label gating **are** worth keeping; the rest needs hardening.
- 7. **Record<string, any> extension APIs + soft-binding everywhere** — graceful degradation at the cost of type safety at security seams. Declare typed APIs; fail at boot.

Useful test-harness tricks

- esbuild transform → `import("data:text/javascript;base64,...")` to test TS source directly, zero build step.
- Adversarial SSE chunking (re-emit fixture bytes in 17-byte then 5-byte slices) to prove parsers aren't line-aligned; truncated stream must reject (`fails closed on a truncated stream` test).
- DI at the port boundary with plain closures, assertion placed *inside* the fake at the exact line that failed in production.
- Malformed persisted records ⇒ dropped, never coerced; wrong schema version ⇒ whole document discarded, defaults used.
- Publication-tree self-proof: `git archive HEAD` → re-add in scratch repo → `write-tree` must equal `HEAD^{tree}` (catches .gitignore swallowing source). 43 lines, runs in CI.

Full extraction disposition (2026-08-26, ORCH)

Every pattern from the three study reports, dispositioned against the live codebase. Statuses: **TASK** (has a PLAN.md task), **COVERED** (already built/decided here), **DEFER** (real, but its wave hasn't arrived — reason given), **CONVENTION** (technique to apply in reviews/specs, not a work item), **REJECT**.

Pattern	Disposition
Approval nonce + generation + epoch triple	TASK-065
Construction-time policy completeness (unmapped tool ⇒ throw)	TASK-066
Enforce-time re-check of enumeration-time filters	TASK-066
Bidirectional closure (stale policy entries with no tool also flagged)	TASK-066 (AC added)
Undescribable ⇒ denied + size cap	TASK-067
Model-directed denial messages	TASK-067

Pattern	Disposition
Refusal memory (denials stick per turn; saturation fails closed; grants not retroactive)	TASK-073
SWR tool discovery keyed by server-set	TASK-068
Closed error registry with payload allowlist	TASK-069
Publication-tree self-proof + negative-control greps	TASK-070
Tool decorators (AsyncContext scope, finally-retire, mandatory toolCallId)	TASK-071
Deferred-bundle provider normalization	COVERED — agent-providers already emits a normalized ProviderEvent stream with costUsd; deltas below
Budget hook in the provider interface + registration completeness (partial provider cannot register)	TASK-072
Provider-namespaced metadata escape hatch	TASK-072
Named injectable scheduling policies (Clock-parameterised, named, unref'd)	TASK-074
Hard-coded canonical-digest fixture pin (regression cannot silently re-baseline)	TASK-074 — key-order fixture exists in packages/shared/test, no literal-hex pin does
Nonce ledger with input-digest binding (same nonce + different content ⇒ error; tri-state lookup)	TASK-075 (db primitive; control-api/telegram wiring after TASK-063 lands)
Lane-based per-agent run scheduler + per-agent turn serialization	TASK-076
Approval-aware health (busy-only-awaiting-approval; safe drain)	TASK-076
Audit dual-sink: capped persistent outbox, Retry-After backoff, exhaustive-union formatter	TASK-077
Admin ceiling as a rank clamp (org policy only tightens)	TASK-078
Ephemeral loopback MCP bridge (hand connectors to CLI harnesses; broker intercepts every tools/call)	TASK-079
Executor-side independent re-verification of approvals	COVERED in principle (atomic SQL consume IS the executing check, N8) — revisit when execution moves out-of-process; then apply TASK-065's binding there too
One canonical digest implementation	COVERED — TASK-003; their 12 divergent copies are the cautionary tale
Atomic single-statement approval transitions	COVERED — TASK-062/064

Pattern

Two-tier validation (hand parsers at process boundaries, zod at model-facing inputs)

Closed method tables + `Object.hasOwn`

Protocol-breach state machine (breach $\Rightarrow$ named shutdown reason)

Secrets never enter the transcript (labelled secret request; value flows control-plane $\rightarrow$ destination)

Process identity binding (generation token in `env+argv`; PID never trusted) + adopt-if-busy supervision

Content-addressed runtime staging + ownership labels + Docker hardening deltas

Pure-function model routing (explicit inputs record)

Model-parameter conflict attribution

Extension kernel (topo-sorted DI graph)

No-cache read-modify-write settings store

Snapshot-act-verify around file mutation; anchor-exactly-once patching; rename-quarantine CAS

esbuild-in-test module loading; adversarial SSE chunking; DI-with-closures fixtures

Structured blocker lists; `not-evaluated` $\neq$ pass

Streaming-parity shims documented in comments

Electron posture (contextIsolation, preload surface, webview hardening)

Regex-guessed tool destructiveness; grep-tests as controls; mock permission service; credentials mounted into sandbox

Disposition

CONVENTION — matches current practice; hold the line in review

COVERED-ish — control-api OpenAPI + ports serve this role; apply the table idiom if a raw RPC surface ever appears

DEFER — no raw long-lived channel exists yet; applies to a future worker $\leftrightarrow$ control-api stream

DEFER to secrets wave — needs its own decompose; N4-critical, do not lose

DEFER — becomes relevant when worker supervises long-lived agent processes

DEFER to sandbox/infra wave — carry the §Anti-patterns 5/6 warnings into that decompose

DEFER to budget/Tier-0 wave (week 5) — adopt the shape then

DEFER — no model catalog exists yet

DEFER/REJECT for now — pnpm package boundaries already give composition; revisit only if a monolithic host process emerges

REJECT — Postgres is the source of truth; the problem it solves (multi-process shared file) doesn't exist here

CONVENTION — apply if/when scripts rewrite config files; DB-centric core doesn't need it

CONVENTION — cite in review when transport parsers appear

CONVENTION — apply in evals wave verdict records

CONVENTION

N/A — no Electron surface

REJECT — anti-patterns, §above

Where this feeds the plan

- **TASK-054** (allowedTools derivation): adopt server-set-keyed discovery cache + enforce-time re-check (§6, tools-discovery pattern).
- **TASK-064 follow-on**: extend approval invalidation with generation/epoch binding (§1).
- **packages/broker**: construction-time policy completeness (§4), describe-or-deny (§2), executor re-verification (§3), refusal memory + model-directed denials (§5).
- **packages/harness-factory**: decorator chain, AsyncContext scope, deferred-bundle provider interface with budget field, Claude SDK strict settings.
- **packages/shared**: canonical-JSON digest liveness test (§7), error registry, scheduling policies.
- **evals/CI**: liveness assertion shapes (§8), publication-tree self-proof, negative-control greps.